



FedRAMP® (High, Moderate, Low, LI-SaaS) Baseline System Security Plan (SSP)

for Marcus

T-Pot O&G Threat Intelligence Honeypot Lab

Version 1.0

8/12/2026

info@fedramp.govfedramp.gov

SYSTEM SECURITY PLAN

Prepared by

Identification of Organization that Prepared this Document	
Organization Name	Marcus (Independent Researcher)
Street Address	N/A — personal lab, address withheld
Suite/Room/Building	N/A
City, State, Zip	N/A

Prepared for

Identification of Cloud Service Provider	
Organization Name	N/A — self-directed personal research project; no specific CSP customer organization.
Street Address	N/A — personal lab, address withheld
Suite/Room/Building	N/A
City, State, Zip	N/A

Document Revision History

Date	Description	Version	Author
08/12/2026	Initial publication	1.0	Marcus



Date	Description	Version	Author
08/12/2026			
08/12/2026			

TABLE OF CONTENTS

1	Introduction.....	8
2	Purpose.....	8
3	System Information.....	8
4	System Owner.....	10
5	Assignment of Security Responsibility.....	11
6	Leveraged FedRAMP-Authorized Services.....	12
7	External Systems and Services Not Having FedRAMP Authorization.....	15
8	Illustrated Architecture and Narratives.....	19
8.1	Illustrated Architecture.....	19
8.2	Narrative.....	22
9	Services, Ports, and Protocols.....	24
10	Cryptographic Modules Implemented for Data At Rest (DAR) and Data In Transit (DIT).....	27
11	Separation of Duties.....	29
12	SSP Appendices List.....	31
	Appendix A T-Pot O&G Threat Intelligence Honeypot Lab FedRAMP Security Controls.....	33
	Appendix B T-Pot O&G Threat Intelligence Honeypot Lab Related Acronyms.....	35
	Appendix C T-Pot O&G Threat Intelligence Honeypot Lab Information Security Policies and Procedures.....	36
	Appendix D T-Pot O&G Threat Intelligence Honeypot Lab User Guide.....	37
	Appendix E T-Pot O&G Threat Intelligence Honeypot Lab Digital Identity Worksheet.....	37
	Appendix F T-Pot O&G Threat Intelligence Honeypot Lab Rules of Behavior (RoB).....	40
	Appendix G T-Pot O&G Threat Intelligence Honeypot Lab Information System Contingency Plan (ISCP).....	40
	Appendix H T-Pot O&G Threat Intelligence Honeypot Lab Configuration Management Plan (CMP).....	41
	Appendix I T-Pot O&G Threat Intelligence Honeypot Lab Incident Response Plan (IRP).....	42



Appendix J T-Pot O&G Threat Intelligence Honeypot Lab Control Implementation Summary (CIS) and Customer Responsibilities Matrix (CRM) Workbook.....	43
Appendix K T-Pot O&G Threat Intelligence Honeypot Lab Federal Information Processing Standard (FIPS) 199 Categorization.....	44
Appendix L T-Pot O&G Threat Intelligence Honeypot Lab-Specific Laws and Regulations.....	47
Appendix M T-Pot O&G Threat Intelligence Honeypot Lab Integrated Inventory Workbook (IIW).....	47
Appendix N T-Pot O&G Threat Intelligence Honeypot Lab Continuous Monitoring Plan.....	48
Appendix O T-Pot O&G Threat Intelligence Honeypot Lab POA&M.....	49
Appendix P T-Pot O&G Threat Intelligence Honeypot Lab Supply Chain Risk Management Plan (SCRMP).....	49
Appendix Q T-Pot O&G Threat Intelligence Honeypot Lab Cryptographic Modules Table.....	50

SYSTEM SECURITY PLAN APPROVALS

Cloud Service Provider (CSP) Signatures

By signing this System Security Plan (SSP), we agree that it is complete and is the current version to be used for the security assessment. [The FedRAMP-specific Laws and Regulations Document](#), as of the date of this SSP, is Version 1.0, dated 08/12/2026, and is posted on the [FedRAMP Documents and Templates webpage](#). The CSO-related laws and regulations, beyond those required by FedRAMP, are captured in Appendix L.

<Sign Here>			
Name	Marcus	Date	08/12/2026
Title	System Owner		
Cloud Service Provider	Marcus		

<Sign Here>			
Name	Marcus	Date	08/12/2026

Title	System Owner
Cloud Service Provider	Marcus

<Sign Here>			
Name	Marcus	Date	08/12/2026
Title	System Owner		
Cloud Service Provider	Marcus		

1 Introduction

The SSP is the “security blueprint” of a CSO. The SSP defines a CSO’s authorization boundary and describes the security controls in place to protect the confidentiality, integrity, and availability (CIA) of the system and federal data it holds.

2 Purpose

This System Security Plan (SSP) documents the security control implementation for the T-Pot O&G Threat Intelligence Honeypot Lab, a single-VM Azure IaaS research and portfolio system. It is written using the official FedRAMP SSP template structure to demonstrate familiarity with formal Assessment and Authorization (A&A) documentation practice at a lab scale; this system is not undergoing FedRAMP authorization and processes no federal data. It should be read together with the SAP and SAR for this system.

3 System Information

System Name: T-Pot O&G Threat Intelligence Honeypot Lab. System Type: Minor Application / General Support System (single-host lab). Environment: Microsoft Azure IaaS, East US region. FIPS 199 Categorization: Confidentiality Low, Integrity Moderate, Availability Low (Moderate high-water mark), used here for RMF-demonstration purposes rather than because the system processes sensitive data. Purpose: deploy a high-interaction, multi-protocol honeypot (T-Pot HIVE edition, including Conpot ICS/SCADA emulation) to collect real-world attacker telemetry against IT and OT/ICS protocols, for security research and Oil & Gas-sector threat-intelligence portfolio demonstration.

4 System Owner

Marcus — System Owner, sole operator and point of contact for this system.

5 Assignment of Security Responsibility

Marcus — System Owner / ISSO equivalent. In a production FedRAMP engagement, security responsibility would typically be distributed across dedicated ISSO, ISSM, and AO roles; for this lab-scale demonstration system, one individual holds all responsibility, as disclosed here rather than obscured.

6 Leveraged FedRAMP-Authorized Services

None. This system does not leverage any FedRAMP-authorized cloud services from another CSP. It is a standalone Azure IaaS deployment using native Azure platform services (Key Vault, Log Analytics, Defender for Cloud) directly.

7 External Systems and Services Not Having FedRAMP Authorization

Microsoft Azure platform services used directly by this system (Virtual Machines, Virtual Network, Network Security Groups, Key Vault, Log Analytics, Microsoft Defender for Cloud) are Microsoft-operated and covered under Azure's own compliance attestations, not independently assessed as part of this lab's RMF package. No other external systems or services are used.

8 Illustrated Architecture and Narratives

This section contains the diagrams and narratives for the T-Pot O&G Threat Intelligence Honeypot Lab authorization boundary, network, and data flows. Section 8.1 provides the diagrams, and Section 8.2 provides the associated narratives.

8.1 Illustrated Architecture

See the SSP diagram in the companion SSP.md (this system's GitHub repository) for the full network/architecture diagram: Internet → Azure Public IP → NSG (management plane restricted to analyst IP; honeypot plane open by design) → VNet/subnet → VM (T-Pot HIVE: 20+ honeypot containers + ELK stack + NGINX) → Log Analytics / Defender for Cloud.

8.2 Narrative

The system is a single Azure Virtual Machine (Ubuntu Linux) running T-Pot HIVE edition, which hosts 20+ containerized honeypot services behind an ELK (Elasticsearch/Logstash/Kibana) stack, fronted by an NGINX reverse proxy over HTTPS. Network access is split into two planes via Azure Network Security Group (NSG) rules: a management plane (SSH, Kibana, T-Pot Web UI) restricted to the system owner's analyst IP address, and a honeypot plane deliberately exposed to the internet across common IT ports and ICS/SCADA protocol ports (Modbus, S7comm, ENIP, BACnet). Conpot runs the Guardian AST template, emulating a petroleum Automatic Tank Gauge, for Oil & Gas-relevant threat intelligence. The VM's OS and data disks are encrypted via Azure Disk Encryption backed by a dedicated Key Vault. Microsoft Defender for Cloud and a Log Analytics workspace provide platform-level monitoring alongside the system's own ELK-based logging.

9 Services, Ports, and Protocols

Management plane (restricted to analyst IP): TCP 64295 (SSH), 64296 (Kibana), 64297 (T-Pot Web UI). Honeypot plane (intentionally open to the internet, by design): TCP 21,22,23,25,80,110,143,443,445,1080,1433,3306,3389,5900,8080,8443 (common IT services); TCP 102,502,44818,47808 and UDP 502,47808,161,162 (ICS/SCADA: S7comm, Modbus, ENIP, BACnet, SNMP); TCP 5555,6667,8888,9200,11211,27017,50000-50001 (extended honeypot services). All other inbound traffic is explicitly denied by the NSG's lowest-priority deny-all rule.

10 Cryptographic Modules Implemented for Data At Rest (DAR) and Data In Transit (DIT)

Data At Rest: Azure Disk Encryption (ADE), OS and data disks, keys managed via a dedicated Azure Key Vault. Data In Transit: TLS/HTTPS via NGINX reverse proxy for the Kibana dashboard and T-Pot Web UI (self-signed certificate in this lab deployment — flagged in the SAR as a finding for any use beyond local/lab access). SSH access uses public-key cryptography (key-based authentication only; password authentication disabled).

11 Separation of Duties

Not formally implemented. As a single-operator lab, the system owner performs all roles (administration, monitoring, assessment). In a production FedRAMP context this would violate separation-of-duties expectations; it is disclosed here as an accepted characteristic of this system's lab scope rather than presented as a compliant control implementation.

12 SSP Appendices List

Appendices below follow the FedRAMP SSP template structure. Most are marked Not Applicable (N/A) with a stated reason — this system is a single-VM personal research lab, not a multi-tenant commercial Cloud Service Offering, and most appendices in this list (Digital Identity Worksheet, Supply Chain Risk Management Plan, Integrated Inventory Workbook, etc.) are scoped for that larger context. Applicable content that does exist for this system (POA&M, Rules of Behavior) is summarized in its appendix entry and documented in full in the companion SAR.md/SSP.md.

Appendix A T-Pot O&G Threat Intelligence Honeypot Lab FedRAMP Security Controls

N/A as a separate workbook — control implementation is documented directly in this SSP's body (Sections 1–3) and in the companion SSP.md, mapped to NIST SP 800-53 Rev. 5 control families (AC, IA, SC, SI, AU, CM, RA) at a scope appropriate to a single-VM lab.

Appendix B T-Pot O&G Threat Intelligence Honeypot Lab Related Acronyms

Standard FedRAMP/NIST acronyms are used throughout this document as defined by the FedRAMP Master Acronym and Glossary. System-specific terms (T-Pot, honeypot module names) are defined at first use in the SSP body.

Appendix C T-Pot O&G Threat Intelligence Honeypot Lab Information Security Policies and Procedures

N/A — no separate organizational policy/procedure document set exists beyond this SSP; as a single-operator lab there is no organization-level policy structure to document.

Appendix D T-Pot O&G Threat Intelligence Honeypot Lab User Guide

N/A — this system has no external end users; the system owner is its sole operator and administrator.

Appendix E T-Pot O&G Threat Intelligence Honeypot Lab Digital Identity Worksheet

N/A — this system does not provide identity services to federal users or process citizen-facing digital identity transactions; NIST SP 800-63 IAL/AAL/FAL determinations are not applicable to a single-operator research lab.

Appendix F T-Pot O&G Threat Intelligence Honeypot Lab Rules of Behavior (RoB)

This system is a decoy/research asset only; no real credentials, PII, or production data may ever be placed on it.

Management access is restricted to the system owner's authorized IP address; NSG source IP must be updated if that IP changes.

Captured malware samples are handled as hostile artifacts — analyzed in isolation, never executed on the host or exfiltrated to non-lab systems.

Public-facing dashboards or screenshots (e.g., for portfolio/LinkedIn use) must not disclose the live public IP, internal analyst IP, or credentials.

Appendix G T-Pot O&G Threat Intelligence Honeypot Lab Information System Contingency Plan (ISCP)

Not formally implemented — accepted gap appropriate to a disposable, non-production lab system. Azure managed-disk durability provides baseline resilience; no RTO/RPO or failover procedure is defined. This gap is documented in the SAR/POA&M rather than falsely claimed as implemented.

Appendix H T-Pot O&G Threat Intelligence Honeypot Lab Configuration Management Plan (CMP)

N/A as a separate document — the system's configuration baseline (sysctl hardening, NSG rule set, sshd_config) is documented directly in this SSP's Control Implementation Summary (Section 3) and version-controlled in the system's GitHub repository, serving the same purpose as a formal CMP at this system's scale.

Appendix I T-Pot O&G Threat Intelligence Honeypot Lab Incident Response Plan (IRP)

N/A as a formal document — this system's core operational function (capturing and analyzing unauthorized access attempts) is itself a form of continuous detection; there is no production impact to respond to. Should the management plane itself be compromised, the response procedure is: revoke SSH keys, rotate the Key Vault, and decommission the VM.

Appendix J T-Pot O&G Threat Intelligence Honeypot Lab Control Implementation Summary (CIS) and Customer Responsibilities Matrix (CRM) Workbook

N/A — this is a single-tenant system with no external customers; there is no customer/provider responsibility split to document. All controls are implemented directly by the system owner, as summarized in this SSP's Section 3.

Appendix K T-Pot O&G Threat Intelligence Honeypot Lab Federal Information Processing Standard (FIPS) 199 Categorization

Confidentiality: Low. Integrity: Moderate. Availability: Low. Overall (high-water mark): Moderate. This categorization is used to demonstrate full RMF documentation practice against a Moderate baseline (per the target job description's emphasis on NIST SP 800-53), not because this system processes data whose loss would have a genuine Moderate-impact consequence — it is a personal research lab processing no PII, no federal data, and no production business data.

Appendix L T-Pot O&G Threat Intelligence Honeypot Lab-Specific Laws and Regulations

N/A as a separate enumeration — the applicable standards used for this system's assessment (NIST SP 800-53 Rev. 5, SP 800-53A, SP 800-37 Rev. 2) are listed in the SAP and SAR. As a personal lab, no CSP-specific federal law/regulation applicability determination was performed.

Appendix M T-Pot O&G Threat Intelligence Honeypot Lab Integrated Inventory Workbook (IIW)

Full asset inventory (in place of a separate workbook, given the small scope): 1x Azure VM (Ubuntu Linux, T-Pot HIVE), 1x Virtual Network with 1 subnet, 1x Network Security Group, 1x static Public IP, 1x Key Vault (disk encryption), 1x Log Analytics workspace, 20+ Docker-hosted honeypot service containers, 1x ELK stack, 1x NGINX reverse proxy. Full detail in the SSP body (Section 1.3/1.4) and SSP.md.

Appendix N T-Pot O&G Threat Intelligence Honeypot Lab Continuous Monitoring Plan

During its operational lifecycle, this system was monitored via Microsoft Defender for Cloud (Standard tier), a connected Log Analytics workspace, fail2ban on the management plane, and ELK-based logging of all honeypot activity. Periodic vulnerability scanning (Nessus credentialed, OpenSCAP CIS Level 2) supplemented continuous monitoring. The system has since been decommissioned; this plan is retained as the historical record of the monitoring approach used.

Appendix O T-Pot O&G Threat Intelligence Honeypot Lab POA&M

The full Plan of Action and Milestones is maintained in the companion SAR.md document. Summary: all POA&M items identified during this system's assessment cycle (OpenSCAP scan-validity issue, Azure IMDS reachability check, an OS/baseline documentation drift item) were closed — either through direct remediation, validation against intended honeypot design, or formal closure via system decommissioning. No items remain open.

Appendix P T-Pot O&G Threat Intelligence Honeypot Lab Supply Chain Risk Management Plan (SCRMP)

N/A — this personal lab has a minimal supply chain (Microsoft Azure as sole cloud provider; T-Pot installed directly from its official GitHub repository). No formal SCRM program was established; software provenance is limited to using official, upstream-maintained sources for the OS image and T-Pot installer.

Appendix Q T-Pot O&G Threat Intelligence Honeypot Lab Cryptographic Modules Table

Data at rest: Azure Disk Encryption (ADE), using platform-managed BitLocker (Windows) / dm-crypt (Linux) underlying encryption, keys stored in a dedicated Azure Key Vault. Data in transit: TLS via NGINX (self-signed certificate in this lab deployment) for Kibana/Web UI; SSH protocol (public-key authentication, symmetric session encryption per OpenSSH defaults) for management access. No FIPS 140-validated module was specifically verified for this lab-scale deployment — noted here rather than falsely claimed.